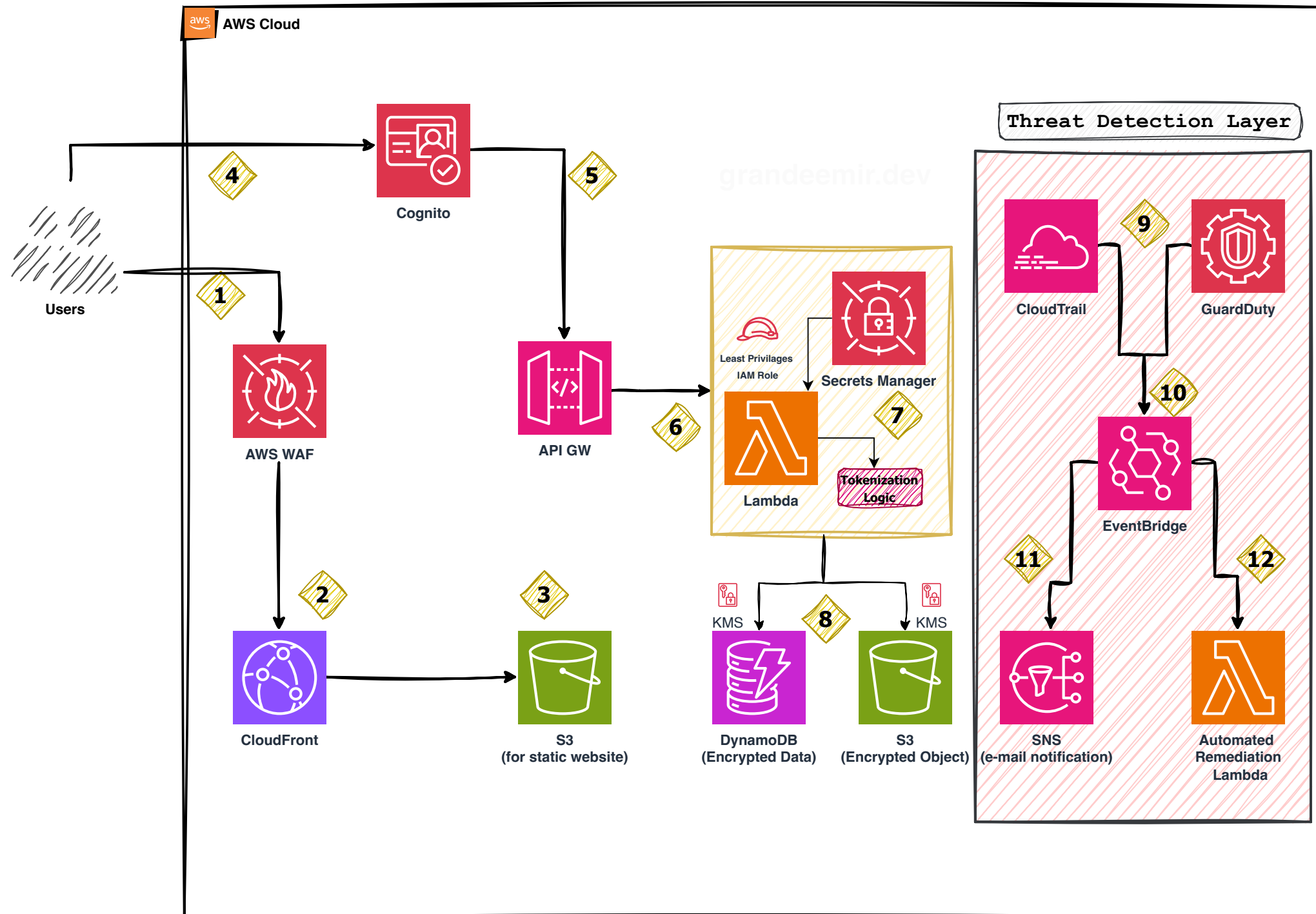


## Zero Trust Serverless Application with Threat Detection



- 1** The request first hits the **Web Application Firewall**. It inspects the traffic for common exploits like SQL Injection or Cross-Site Scripting (XSS) and applies rate-limiting to block bots.
- 2** If the request is safe, it reaches the **CDN**. If doesn't WAF block the user.
- 3** CloudFront fetches your static assets (React/Vue/HTML) from an **S3 bucket** (secured via OAC) and serves them to the user from the nearest edge location.
- 4** The user logs in. Their credentials go directly to **Cognito**. Upon successful authentication, Cognito issues a **JWT (JSON Web Token)**. This token is stored in browser and attached to the header of every subsequent API requests.
- 5** When the user performs an action (e.g., POST /create-todo), the request hits the **API Gateway**. The Gateway automatically validates the JWT. If the token is missing or invalid, the request is rejected immediately at the door, saving you from unnecessary Lambda execution costs.
- 6** Once authorized, the request triggers a **Lambda function**.
- 7** Instead of hardcoding credentials, Lambda retrieves them from **Secrets Manager**. The diagram also highlights **Tokenization Logic** to protect sensitive data during processing.
- 8** All data at rest in **DynamoDB** and **S3** is encrypted using **AWS KMS** keys to ensure compliance and data security.
- 9** **CloudTrail** logs every API call, while **GuardDuty** uses machine learning to analyze those logs for malicious activity or unauthorized
- 10** When GuardDuty finds a threat, it triggers an event in **Amazon EventBridge**.
- 11** EventBridge sends a real-time alert via **SNS** to notify the security team via email or SMS.
- 12** This is the most advanced part of the flow. A dedicated **Lambda** function is automatically triggered to take immediate action, such as revoking compromised **IAM** keys or updating **WAF** rules to block an attacker's IP.